
Risk Management Report

Target: `demo.owasp-juice.shop`

Date of Scan: June 17, 2025

Tools Used: Parrot OS, Parrot Terminal, Nmap with vulnerability scripts

Executive Summary

A vulnerability scan was conducted against the public web application `demo.owasp-juice.shop` using Nmap on Parrot OS. The goal was to identify insecure services, exposed ports, and known vulnerabilities. The scan revealed several open services, including FTP, HTTP proxies, and an SSL-enabled Apache HTTP server. Notably, three vulnerability indicators were identified, including a confirmed Apache DoS weakness and a phpMyAdmin Local File Inclusion (LFI) issue that, while unconfirmed, represents serious potential risk. The following sections break down each of the vulnerabilities with detailed analysis and recommended mitigations.

Detailed Risk Analysis

1. CVE-2011-3192 – Apache byterange filter DoS

The most prominent confirmed vulnerability is **CVE-2011-3192**, which affects the Apache HTTP Server running on port 443. This flaw stems from how Apache handles overlapping byte-range headers in HTTP requests. When exploited, it can lead to a **denial-of-service (DoS)** condition, where the server becomes unresponsive or crashes. This is a classic **availability risk**, and it's particularly concerning because it can be triggered remotely with minimal effort.

Apache is a critical service on this host, and its exposure to the internet significantly increases the likelihood of exploitation. This vulnerability is well-known and actively scanned for by automated bots and attackers alike. Because of the ease of execution and its potential impact on system availability, this risk is rated as **high severity**. Mitigation requires updating Apache to a patched version and applying specific configuration rules to disable or control byte-range requests.

2. CVE-2005-3299 – phpMyAdmin Local File Inclusion (LFI)

The second identified vulnerability involves a possible **Local File Inclusion** (LFI) flaw in the **phpMyAdmin** service exposed on port 8080. Referenced as **CVE-2005-3299**, this issue allows an attacker to include arbitrary local files using a specially crafted **subform** parameter in the **grab_globals.lib.php** script. While the scanner could not confirm this vulnerability during the session, the presence of an exposed phpMyAdmin service still poses a high risk.

phpMyAdmin is an administrative interface for MySQL databases and is often targeted by attackers due to its power and access level. Even if this specific CVE is not exploitable in the current setup, the exposure of phpMyAdmin without access restrictions could lead to other attacks like brute force, privilege escalation, or session hijacking. This vulnerability, if present, poses a **confidentiality and integrity** risk. The risk is considered **high in potential severity**, and mitigation involves disabling or restricting public access to phpMyAdmin, applying access control lists (ACLs), enforcing strong credentials, and updating the application.

3. CVE-2011-1002 – Avahi NULL UDP DoS (Not Vulnerable)

During the pre-scan phase, the tool checked for **CVE-2011-1002**, which is a known denial-of-service issue in **Avahi**, a multicast DNS service. This vulnerability can be exploited through NULL UDP packets to crash the daemon. However, the scanner determined that the system was **not vulnerable**, and no further action is needed at this time.

Still, the detection highlights that Avahi is active or partially detectable, which may be unnecessary for a public-facing server. For hardening purposes, it is recommended to **review Avahi's role** in the environment and **disable it** if not explicitly required.

Critical Assets Identified

- **Apache HTTP Server 2.4.63 (Unix)** — Core web service, confirmed vulnerable
- **phpMyAdmin (via port 8080)** — Highly sensitive database interface, potentially exposed
- **FTP Service (port 21, ftpd.bin 3.4.0r16)** — Legacy protocol, potentially unencrypted and insecure
- **F5 BIG-IP Load Balancer Services (ports 80 and 8080)** — Gateway layer that could be targeted for misconfigurations

These components are considered **high-value assets** due to their exposure on public IPs and the level of access they offer if compromised.

Threat Commentary

The scan revealed a mix of confirmed and potential vulnerabilities, with several outdated and exposed services that raise red flags. The confirmed **Apache DoS vulnerability** should be prioritized due to its high availability impact. The **phpMyAdmin instance** also requires immediate attention because of its history of security issues and the potential LFI flaw.

The **FTP service** — while not tied to a specific CVE — poses significant risk as a legacy protocol that does not encrypt traffic by default. If used for login or file transmission, it could expose sensitive credentials to interception.

Although Avahi was not found to be vulnerable, its broadcast presence should be questioned. In secure environments, **minimizing the digital footprint** of background services is a core principle of defense in depth.

Recommendations

1. **Patch Apache HTTP Server** to eliminate CVE-2011-3192 and apply byte-range request filtering.
2. **Restrict or remove public access to phpMyAdmin**; update it and enforce authentication protections.
3. **Retire the FTP service** or migrate to secure alternatives like **SFTP or FTPS**.
4. **Disable Avahi** if it is not required for core functionality.
5. **Reduce surface exposure** by closing unnecessary ports and auditing load balancer configurations.
6. Establish a regular vulnerability scanning schedule and implement automated alerting for new CVEs.